

2018-11-13 TRAFFIC ANALYSIS EXERCISE - ANSWERS

<https://www.malware-traffic-analysis.net/2018/11/13/index.html>

LAN segment details:

- LAN segment range: 10.22.15.0/24 (10.22.15.0 through 10.22.15.0.255)
- Domain: geeographic.com
- Domain controller: 10.22.15.2 - Geeographic-DC
- LAN segment gateway: 10.22.15.1
- LAN segment broadcast address: 10.22.15.255
- IP address of the Windows client to investigate: 10.22.15.119

Tasks:

- What was the date and time the malicious traffic started?
- What is the MAC address of the infected Windows host?
- What is the host name of the infected Windows host?
- What is the user account name used on the infected Windows host?
- What URL in the pcap returned a Windows executable file?
- What is the size of the Windows executable file from that URL?
- What is the SHA256 hash of the Windows executable file from that URL?
- What type of malware is the Windows executable returned from that URL?

ANSWERS:

- Date/Time malicious activity started: **2018-11-07 at 20:47 UTC**
- MAC address of the infected Windows: **00:11:2f:d1:6e:52**
- Host name of the infected Windows host: **Danger-Win-PC**
- User account name on the infected Windows host: **carlos.danger**
- URL that returned an EXE: **shumbildac[.]com/WES/fatog.php?l=ngul5.xap**
- Size of the EXE: **439,808 bytes**
- SHA256 hash of the EXE: **97f149f146b0ec63c32abff204ae27638f0310536172b0f718f1a91a5672fe71**
- Type of malware: **Ursnif or Gozi/IFSB**

DETAILS:

As always before doing these exercises, I recommend you customize your column display in Wireshark. I've written a guide here:

- <https://researchcenter.paloaltonetworks.com/2018/08/unit42-customizing-wireshark-changing-column-display/>

Q: What was the date and time the malicious traffic started?

A: 2018-11-07 at 20:47 UTC

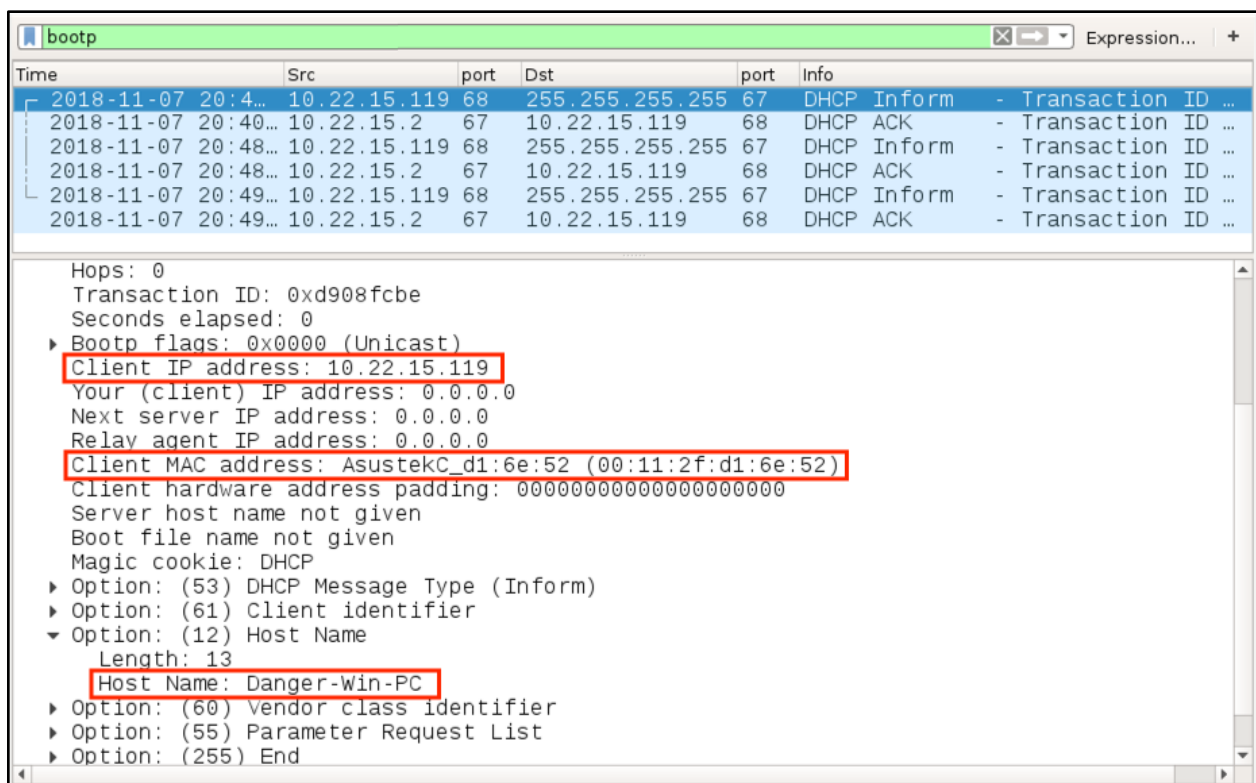
2018-11-13 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Details: The alerts file shows 20:47 UTC on 2018-11-07 as the date and time of the first alert. This is when a Windows executable file was retrieved by the Windows client (more on this below).

Q: What is the MAC address of the infected Windows host?

A: 00:11:2f:d1:6e:52

Details: You can correlate the IP address with the MAC address in the frame details section. Furthermore, you can correlate the IP address, MAC address, and host name using DHCP traffic by filtering on **bootp**. Any of the frames with "DHCP inform" should reveal this information when you dig into the frame details as shown below.



The image shows a Wireshark packet capture window with the filter 'bootp'. The packet list displays several DHCP messages. The packet details pane for a selected DHCP Inform packet shows the following information:

- Hops: 0
- Transaction ID: 0xd908fcbe
- Seconds elapsed: 0
- Bootp flags: 0x0000 (Unicast)
- Client IP address: 10.22.15.119
- Your (client) IP address: 0.0.0.0
- Next server IP address: 0.0.0.0
- Relay agent IP address: 0.0.0.0
- Client MAC address: AsustekC_d1:6e:52 (00:11:2f:d1:6e:52)
- Client hardware address padding: 00000000000000000000
- Server host name not given
- Boot file name not given
- Magic cookie: DHCP
- Option: (53) DHCP Message Type (Inform)
- Option: (61) Client identifier
- Option: (12) Host Name
 - Length: 13
 - Host Name: Danger-Win-PC
- Option: (60) Vendor class identifier
- Option: (55) Parameter Request List
- Option: (255) End

Shown above: DHCP traffic that shows IP address, MAC address, and host name.

Q: What is the host name of the infected Windows host?

A: Danger-Win-PC

Details: In addition to DHCP traffic, you can also find the host name through NetBIOS Name Service (NBNS) traffic by filtering on **nbns** and seeing which host name is associated with the Windows client at 10.22.15.119.

2018-11-13 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Time	Src	port	Dst	port	Info
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB GEEOGGRAPHIC<00>
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB GEEOGGRAPHIC<00>
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB GEEOGGRAPHIC<00>
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Registration NB DANGER-WIN-PC<
2018-11-07 20:40...	10.22.15.119	137	10.22.15.255	137	Name query NB WPAD<00>

Shown above: NBNS traffic that reveals the name of the Windows client.

Q: What is the user account name used on the infected Windows host?

A: carlos.danger

Details: Filter on Kerberos.CNameString to get this info. It's easy to find, if you've customized the Wireshark column display according to [the guide I mentioned earlier](#), and you already have a column already set up to display the CNameString field.

Time	Src	port	Dst	port	CNameString	Info
2018-11-07 20:40...	10.22.15.119	49161	10.22.15.2	88	danger-win-pc\$	AS-REQ
2018-11-07 20:40...	10.22.15.119	49162	10.22.15.2	88	danger-win-pc\$	AS-REQ
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49162	DANGER-WIN-PC\$	AS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49163	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49164	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49167	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49170	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49176	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49177	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49181	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49182	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:40...	10.22.15.119	49187	10.22.15.2	88	DANGER-WIN-PC\$	AS-REQ
2018-11-07 20:40...	10.22.15.119	49188	10.22.15.2	88	DANGER-WIN-PC\$	AS-REQ
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49188	DANGER-WIN-PC\$	AS-REP
2018-11-07 20:40...	10.22.15.2	88	10.22.15.119	49189	DANGER-WIN-PC\$	TGS-REP
2018-11-07 20:41...	10.22.15.119	49190	10.22.15.2	88	carlos.danger	AS-REQ
2018-11-07 20:41...	10.22.15.119	49191	10.22.15.2	88	carlos.danger	AS-REQ
2018-11-07 20:41...	10.22.15.2	88	10.22.15.119	49191	carlos.danger	AS-REP
2018-11-07 20:41...	10.22.15.2	88	10.22.15.119	49192	carlos.danger	TGS-REP
2018-11-07 20:41...	10.22.15.2	88	10.22.15.119	49194	carlos.danger	TGS-REP
2018-11-07 20:41...	10.22.15.2	88	10.22.15.119	49196	carlos.danger	TGS-REP
2018-11-07 20:41...	10.22.15.2	88	10.22.15.119	49199	carlos.danger	TGS-REP
2018-11-07 20:41...	10.22.15.2	88	10.22.15.119	49200	carlos.danger	TGS-REP

Shown above: Wireshark filtered on Kerberos traffic and the CNameString field.

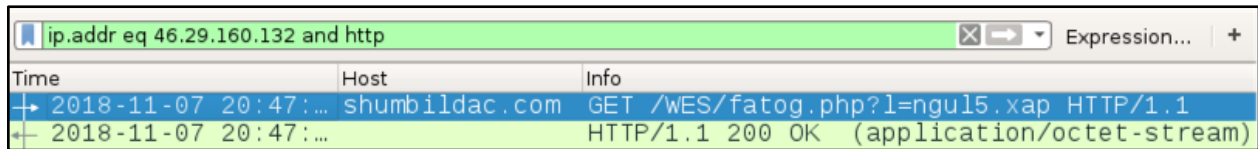
Q: What URL in the pcap returned a Windows executable file?

A: shumbildac[.]com/WES/fatog.php?l=ngul5.xap

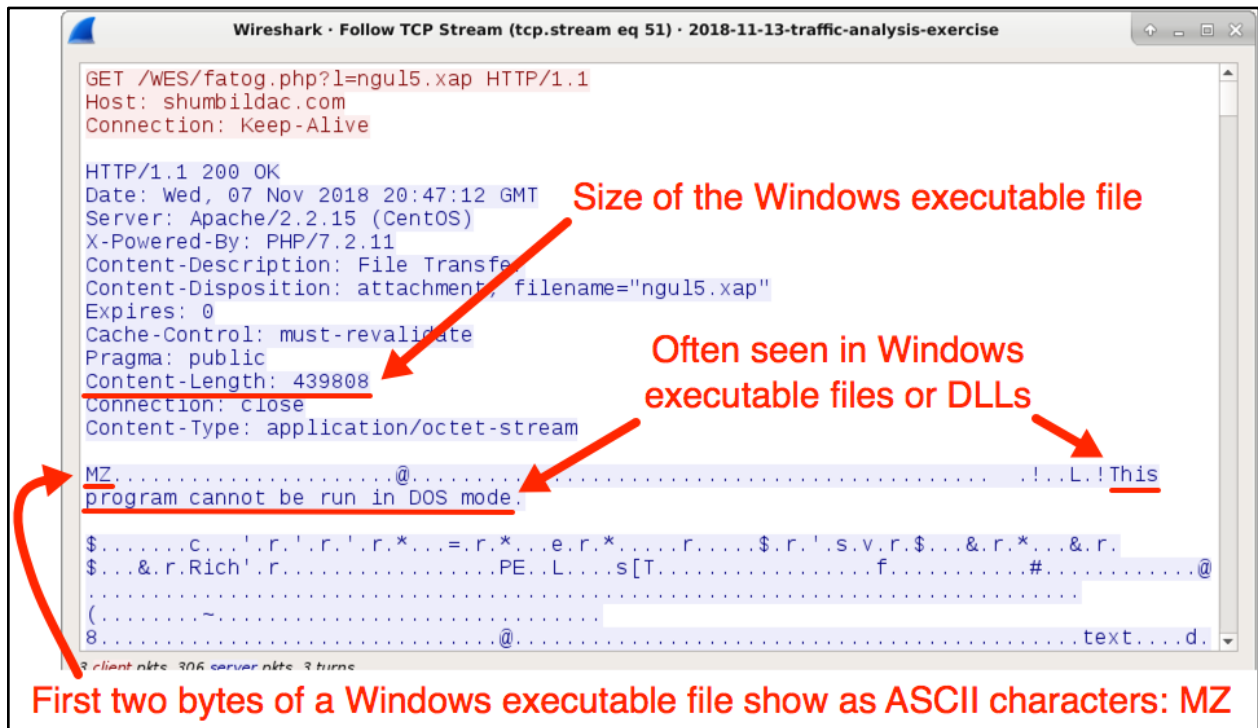
Details: The alerts show a Windows binary downloaded from 46.29.160.132, so you can filter on this information in Wireshark by using **ip.addr eq 46.29.160.132 and http**

2018-11-13 TRAFFIC ANALYSIS EXERCISE - ANSWERS

to get a better look. Follow the TCP stream for either of the frames displayed, and you'll see signs of a Windows executable file.



Shown above: Filtering on traffic from the first few alerts on a Windows binary.



Shown above: Following the TCP stream reveals the Windows executable file.

Q: What is the size of the Windows executable file from that URL?

A: 439,808 bytes

Details: See the above image for details.

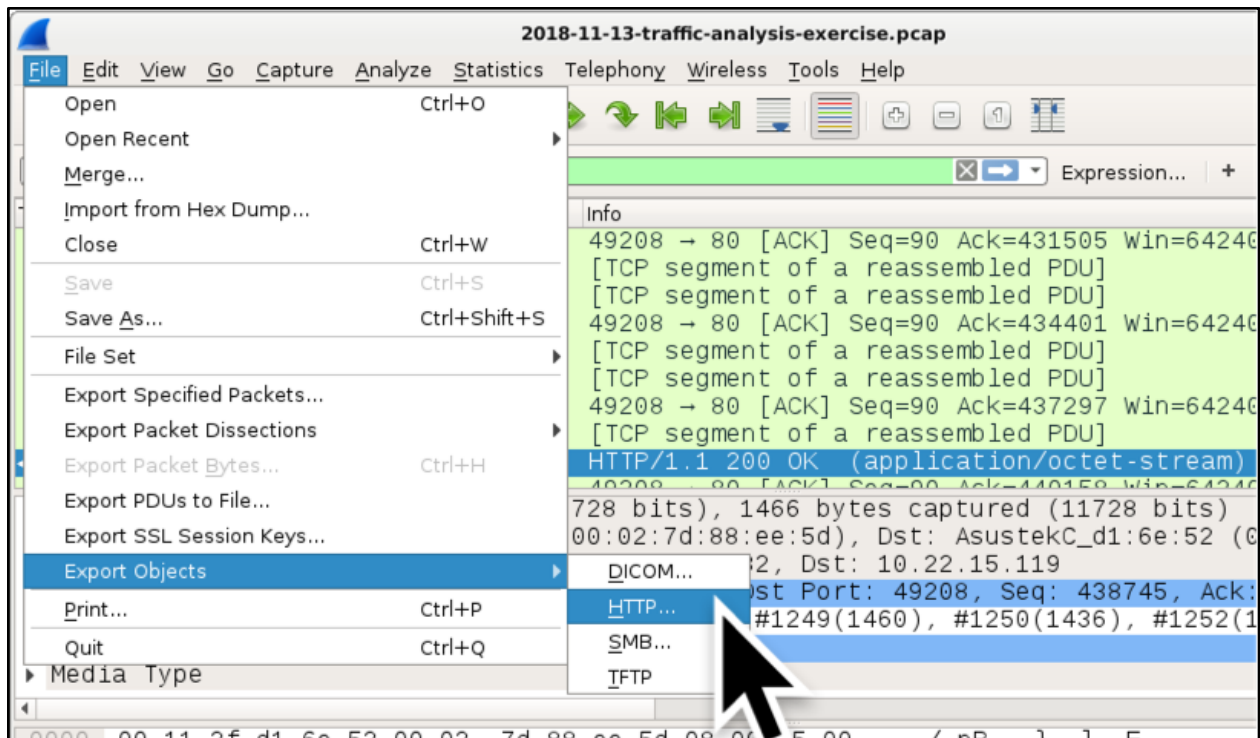
Q: What is the SHA256 hash of the Windows executable file from that URL?

A: 97f149f146b0ec63c32abff204ae27638f0310536172b0f718f1a91a5672fe71

Details: To find the SHA256 hash of the Windows executable file, you need to export it from the pcap. This can be done by using the menu path:

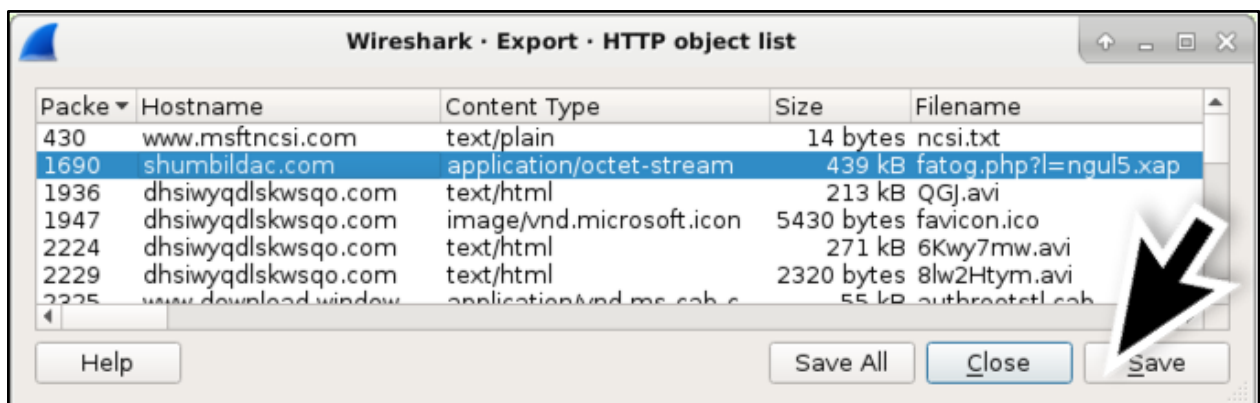
File → Export Object → Http...

2018-11-13 TRAFFIC ANALYSIS EXERCISE - ANSWERS



Shown above: Exporting objects from the HTTP traffic in Wireshark.

This will bring up an HTTP object list, and you can select the line for hostname ***shumbildac[.]com*** and save the binary. Beware this is actual Windows malware. It will infect a Windows computer, if not properly handled. I highly recommend people use a non-Windows computer to review these exercises (like a Linux computer or a MacBook).



Shown above: Saving the Windows executable to your local host.

You can then submit the file to VirusTotal to get the hash. If you're doing this exercise on a Linux, BSD, or MacBook, you can use the shasum command.

shasum -a 256 [filename or path to file]

2018-11-13 TRAFFIC ANALYSIS EXERCISE - ANSWERS

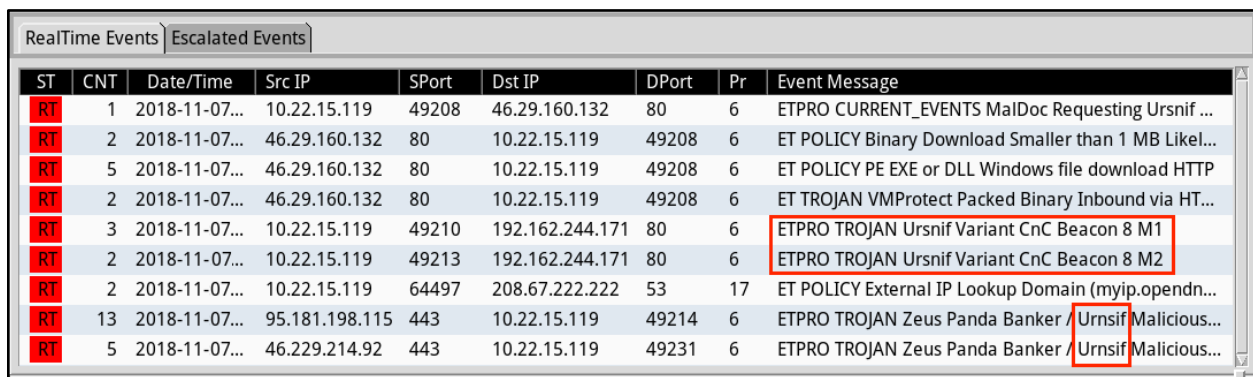
Q: What type of malware is the Windows executable returned from that URL?

A: Ursnif or Gozi/IFSB

Details: The alerts file has alerts for Ursnif and other alerts about malicious SSL certificates for "Zeus Panda Banker / Ursnif" meaning these sorts of certificates are used by either type of malware.

But this is Ursnif traffic. Based on my experience with this type of malware, I've tagged the VirusTotal entry as #Ursnif, while the [URLhaus entry on the shumbildac\[.\]com URL is tagged Ursnif and Gozi](#).

Gozi (also shown as Gozi/ISFB) is a variant of Ursnif, and people often use either name for the malware.



ST	CNT	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	2018-11-07...	10.22.15.119	49208	46.29.160.132	80	6	ETPRO CURRENT_EVENTS MalDoc Requesting Ursnif ...
RT	2	2018-11-07...	46.29.160.132	80	10.22.15.119	49208	6	ET POLICY Binary Download Smaller than 1 MB Likel...
RT	5	2018-11-07...	46.29.160.132	80	10.22.15.119	49208	6	ET POLICY PE EXE or DLL Windows file download HTTP
RT	2	2018-11-07...	46.29.160.132	80	10.22.15.119	49208	6	ET TROJAN VMProtect Packed Binary Inbound via HT...
RT	3	2018-11-07...	10.22.15.119	49210	192.162.244.171	80	6	ETPRO TROJAN Ursnif Variant CnC Beacon 8 M1
RT	2	2018-11-07...	10.22.15.119	49213	192.162.244.171	80	6	ETPRO TROJAN Ursnif Variant CnC Beacon 8 M2
RT	2	2018-11-07...	10.22.15.119	64497	208.67.222.222	53	17	ET POLICY External IP Lookup Domain (myip.opendn...
RT	13	2018-11-07...	95.181.198.115	443	10.22.15.119	49214	6	ETPRO TROJAN Zeus Panda Banker / Ursnif Malicious...
RT	5	2018-11-07...	46.229.214.92	443	10.22.15.119	49231	6	ETPRO TROJAN Zeus Panda Banker / Ursnif Malicious...

Shown above: Alerts on the infection traffic from the EmergingThreats Pro ruleset in Squil on Security Onion.

NOTE: A bunch of traffic in this pcap is not related to the infection. For example, all of the web traffic to **www.ucdenver.edu** is just the infected user viewing a page or two from **www.ucdenver.edu**. It is not malicious, and it has nothing to do with the Ursnif infection.

Like many of these exercises, this one is useful for newer analysts. Hopefully it also has some tips for more established security professionals. And I hope you've enjoyed doing this exercise.

Until next time!